

과제 8

패스키로 잠근 소개 페이지

비밀번호 없이 나만 들어가기 — WebAuthn 패스키

공개 결과물 <https://webtest-passkey.vercel.app>

소스 <https://github.com/stulss/webtest-passkey>

한눈에

무엇을 만들었고 무엇으로 증명했는가

47 / 47

통과 기준 충족

15장

증거 스크린샷

8 / 8

자동 테스트

0

비밀번호 입력칸

1 무엇을 잠갔나

- 공개 소개 페이지(과제 1)는 그대로 — 누구나 봄
- 새로 만든 /private 만 패스키로 잠금
- 비밀번호는 만들지 않음. 입력칸도 없음
- 등록 시 공개키만 서버로, 개인키는 기기 밖으로 안 나감
- 로그인마다 서버가 새 질문(challenge)을 냄

2 무엇으로 증명했나

- 실제 배포본에 요청을 보낸 요청·응답 기록
- Chrome + CDP 가상 인증기로 자동 촬영한 화면
- 프로덕션 Redis 를 직접 조회한 저장 내용
- 실기기(구글 비밀번호 관리자) 등록 프롬프트

과제 1에서 이어 만든 것

공개 내용은 그대로 남기고, 잠긴 자리만 새로 붙였다

과제 1 · webtest

- 정적 Vanilla JS · OOP MVC
- index.html + css +
js/{models,views,controllers}
- GitHub Pages 배포
- 백엔드 없음

옮긴 것

- Next.js 16 App Router 로 이식
- PORTFOLIO_DATA → app/portfolio-data.ts
- style.css → app/globals.css
- 공개 내용은 한 글자도 바꾸지 않음

새로 만든 것

- /private 비공개 영역
- /login 패스키 등록·로그인
- /api/webauthn/* 서버 라우트
- Redis 저장소 + 세션

왜 서버가 필요했나 — 패스키는 challenge 발급·보관(1회성), attestation/assertion 서명 검증, 공개키 저장, 세션 유지를 서버가 해야 한다. 정적 호스팅 (GitHub Pages)으로는 불가능해서 Vercel + Redis 로 옮겼다. 원본 webtest 저장소와 Pages 배포는 건드리지 않았다.

공개 소개 페이지

첫 화면은 누구나 본다 — 로그인·초대·CAPTCHA 없음

아무것도 등록하지 않아도 열린다

- 과제 1의 이름·소개 문장·강점·프로젝트·기술·공개 범위
가 그대로
- 서버 컴포넌트이며 익명 방문자에게는 DB 조회가 0건
- 하단에 '지어낸(fabricated) 내용' 고지 — 실제 개인정보
없음

T08-C01 · C03 · C10 · C11 · C12

홍주형 · PORTFOLIO

공개 소개비공개 영역

PORTFOLIO

홍주형

공조냉동설비 기사를 준비하며 Python과 MySQL을 독학하고, 그 배움을 이 포트폴리오 웹사이트로 직접 기획·제작했습니다.

최근 공부한 내용

취미

관심 분야

GitHub에서 근거 보기

강점

항목을 눌러 상황·행동·결과를 자세히 볼 수 있습니다.

강점 1. 새로운 분야에 도전하는 실행력

강점 2. 몰입해서 나를 채우는 힘

강점 3. 관심 있는 것을 직접 파고드는 힘

프로젝트

직접 만든 프로젝트와, 만들면서 실제로 겪은 결함·해결 과정입니다.

공개 영역과 비공개 영역

어디까지가 공개이고 어디부터가 비공개인지 화면에서 갈라 둔다

구분선 + 자물쇠 라벨로 경계를 그었다

- 위: 공개 영역 안내 — '로그인 없이 누구나 봅니다'
- 점선 구분선 아래부터  비공개 영역 · 나만 볼 수 있습니다
- 비공개 항목 3건 (준비 중인 메모 · 지원 목록 · 회고 성격)
- 항목은 전부 지어낸 내용이며 화면에도 그 사실을 적어둠

T08-C13 · C14



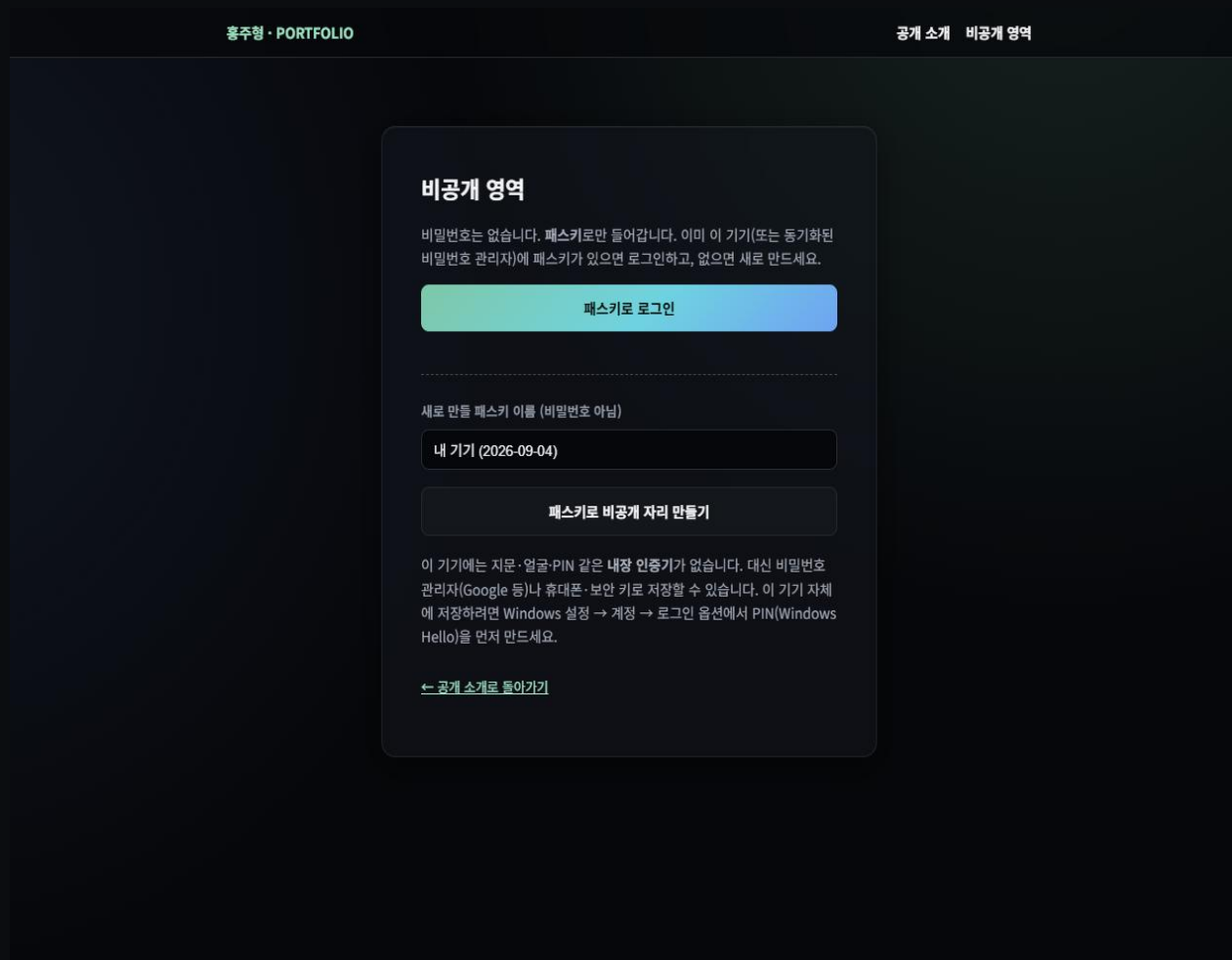
잠겨 있다

패스키 없이는 화면에도, 페이지 소스에도 없다

/private 를 직접 쳐도 로그인 화면으로

- proxy.ts 가 세션 쿠키 없는 요청을 /login 으로 307
- 화면 컴포넌트 첫 줄이 requirePageUser() — SSR 도달 전에 차단
- 받은 페이지 소스에서 '회고·지원·프로젝트 메모' 검색 → 0건
- 즉, 숨기기를 화면에서만 한 게 아니다

T08-C15 · C18



인증 구현 설명서 ① 무엇으로 붙였나

라이브러리 · 직접 구현 · 인증 서비스 중 무엇인가

영역	무엇을 썼나	직접/라이브러리
WebAuthn 크립토	@simplewebauthn/server v13 · @simplewebauthn/browser v13	라이브러리
세션	불투명 난수 토큰. 쿠키엔 원문, 서버엔 sha256 해시만	직접 구현
앱	Next.js 16 App Router	—
저장소	Redis (Vercel Marketplace → Redis Cloud, TCP) · ioredis	—
인증 서비스	사용하지 않음 (Auth.js·Clerk·Hanko 등 없음)	해당 없음

서명 검증(암호화 부분)은 검증된 라이브러리에 맡기고, 세션은 직접 구현했다.

- 비밀번호는 만들지 않았다 — 로그인 화면에도, 코드에도, 저장소에도 비밀번호 칸·해시가 없다
- 로그인 방식은 usernameless(discoverable) — 아이디 입력칸조차 없이 브라우저가 패스키를 고른다
- 회원가입도 없다 — 패스키를 처음 등록하면 그 사람 몫의 '비공개 자리'가 생긴다

인증 구현 설명서 ② 왜 그걸 골랐나

고른 이유와, 검토했지만 고르지 않은 것

✓ 고른 이유

- 과제가 '비밀번호를 아예 쓰지 않고 잠그기' → 패스키
- WebAuthn 크립토는 CBOR/COSE 파싱과 ECDSA 검증이라 직접 짜면 미묘한 버그가 난다 → 검증된 라이브러리
- 로그아웃·자리 삭제 즉시 폐기해야 해서 만료 전까지 유효한 서명 토큰(JWT) 대신 서버 세션
- usernameless 라 '비밀번호 입력칸 없음'이 확실하다
- 저장소는 challenge 의 TTL·1회 소비가 SET EX + GETDEL 한 줄이라 Redis

✗ 검토했지만 고르지 않은 것

크립토 직접 구현

COSE 파싱·서명 검증 버그 위험, 검증 시간 증가

Auth.js / Clerk / Hanko

외부 인증 서비스 의존. 토큰 만료 전 즉시 폐기를 따로 설계해야 함

Supabase Postgres

schema.sql·접속 문자열 2종·풀러 설정. 이 규모엔 설정 대비 이득이 적음

비밀번호 폴백 / 이메일 복구

과제 범위 밖. 복구 부재는 ⑥에 밝힘

인증 구현 설명서 ③ 어디를 어떻게 고쳤나

등록 · 로그인 · 로그아웃 · 비공개 자료 조회 — 네 흐름이 지나는 자리

흐름	화면 / API	소스 경로 체인
등록	/login · /private → POST /api/webauthn/register/{options,verify}	app/login/page.tsx · app/private/passkeys.tsx → app/webauthn-client.ts → app/api/webauthn/register/*/route.ts → lib/service/auth.ts → lib/webauthn.ts → lib/repository/{challenge,user,credential}.ts
로그인	/login → POST /api/webauthn/authenticate/{options,verify}	app/webauthn-client.ts → app/api/webauthn/authenticate/*/route.ts → lib/service/auth.ts(authenticateStart·Finish) → lib/webauthn.ts(verifyAuthenticationResponse) → lib/session.ts:createSession
로그아웃	POST /api/auth/logout	app/private/passkeys.tsx → app/api/auth/logout/route.ts → lib/session.ts:destroySession → lib/repository/session.ts (DEL session:{hash})
비공개 조회	/private · GET /api/items	proxy.ts(쿠키 1차 관문) → app/private/page.tsx(requirePageUser) 또는 app/api/items/route.ts(getSessionUser→unauthorized) → lib/service/item.ts → lib/repository/item.ts(키를 항상 space:{spaceId}) → lib/dto/records.ts

자리 ID(spaceId)는 lib/session.ts:getSessionUser() — 쿠키에서만 온다. URL·헤더·요청 본문에서 읽는 코드는 이 프로젝트에 없다.

저장소 구조

관계형 DB 아님 — Redis 키 하나하나가 무엇인지

키	값	비고
space:{spaceId}	{ userHandle, createdAt }	비공개 자리 = 이 키 하나. 이름·이메일·비밀번호 없음
cred:{credentialId}	{ spaceId, publicKey, counter, deviceType, backedUp, transports, aaguid, label, ... }	공개키 저장. 개인키 없음
space:{id}:creds	credentialId 들의 SET	패스키 목록 · excludeCredentials · 마지막 1개 판정
challenge:{id}	{ purpose, challenge, spaceId?, rpId, ... }	EX 300(5분). 소비는 GETDEL — 원자적 1회
challenge:audit	최근 발급 목록 (capped 200)	'질문이 매번 다르다'의 서버측 로그
session:{sha256}	spaceId	EX 7일. 쿠키엔 원문, 여기엔 해시만. 로그아웃 = DEL
item:{itemId}	{ spaceId, content, createdAt }	자리별 격리 대상

비밀번호·해시에 해당하는 키는 스키마 어디에도 없다.

등록 흐름

기기가 열쇠 한 쌍을 만들고, 공개키만 서버로 간다

1 서버

randomBytes(16) 로 user handle 생성.
generateRegistrationOptions(residentKey: required
)

2 서버

challenge 를 Redis 에 저장 (EX 300).
행 id 를 익명 쿠키 to8_webauthn 에

3 기기

키쌍 생성 → 개인키와 user handle 을
resident key 로 기기에 저장. 개인키는 밖으로 안
나감

4 브라우저

attestationObject · clientDataJSON · transports
만 서버로 전송 (개인키 없음)

5 서버

GETDEL 로 challenge 소비 →
verifyRegistrationResponse(expectedChallenge = 저
장값)

6 서버

space + cred:{id} 에 공개키 저장.
첫 등록이면 세션 발급

등록을 중간에 취소하면 verify 가 호출되지 않아 challenge 는 TTL 로 사라지고 서버에 아무것도 저장되지 않는다. 화면에는 '등록을 취소했습니다. 저장된 것은 없습니다.' 가 뜬다. (C25)

로그인 흐름

서버가 매번 새 질문을 내고, 저장해 둔 공개키로 서명을 확인한다

- 1 generateAuthenticationOptions(allowCredentials 생략)
→ usernameless. 브라우저가 패스키 선택 UI 를 띄운다
- 2 새 challenge 를 Redis 에 저장 (EX 300) → 익명 쿠키
- 3 기기가 개인키로 challenge 에 서명 → signature 반환
(개인키가 아니라 서명이 온다)
- 4 GETDEL 로 challenge 소비 — 이 시점에 1회성이 확정된다
- 5 cred:{response.id} 조회 → 없으면 400 '등록되지 않은 패스키입니다'
- 6 verifyAuthenticationResponse(publicKey: 저장값) 통과 후에만
세션 발급. 실패하면 401

추가 방어 — response.userHandle 이 그 크리덴셜의 자리와 일치하는지 교차 확인하고, 서명 카운터를 갱신한다.

인증 구현 설명서 ④ 안 열리는 것을 확인한 기록

확인 네 가지 — 성공한 요청과 거절된 요청을 나란히

확인	성공한 요청	거절된 요청	기준
로그인 없이 열기	로그인 후 GET /api/items → 200 (3건)	쿠키 없이 GET /api/items → 401 /private → 307 → /login	C16 · C17 · C18
남의 패스키로 열기 (자리 격리)	각 자리가 자기 POST /api/items → 201	A→B, B→A 모두 DELETE → 404 ?user_id=OTHER 붙여도 내 것만 양쪽 건수 3 → 3 불변	C36 ~ C40
이미 쓴 질문 재사용	authenticate/verify (challenge 첫 사용)	같은 challenge 재사용 → 400 '인증 요청이 만료되었거나 이미 처리되었습니다'	C31 · C33
패스키 삭제 뒤 로그인	삭제 후 남은 패스키로 → 200	삭제된 패스키로 → 400 마지막 패스키 삭제 시도 → 409	C44 · C45 · C46

추가로 서명 검증 성공(200) / 1바이트 변조 서명(401) 을 나란히, 로그아웃 뒤 이전 세션 재사용(401) 도 기록했다. (C29 · C30 · C33)

확인 ① 로그인 없이 열기

화면이 아니라 서버가 막는다

쿠키 없이 직접 요청 → 401

- 브라우저에 그대로 401 과 본문이 보인다
- {"error":"로그인이 필요합니다."}
- /private 는 307 로 /login 으로 보낸다
- 받은 페이지 소스에 비공개 항목 텍스트 0건

T08-C16 · C17 · C18

pretty print 적용

GET /api/items (쿠키 없음) → HTTP 401

```
{"error":"로그인이 필요합니다."}
```

확인 ② 남의 패스키로는 안 열린다

자리가 둘이고, 서로의 자료가 보이지 않는다

두 번째 자리는 자기 항목만 3건

- 첫 자리와 내용이 완전히 다르다
- 자리 B 세션으로 자리 A 의 항목 삭제 시도 → 404
- 반대 방향도 404, 양쪽 건수 3 → 3 불변
- 주소에 남의 계정을 적어도(?user_id=OTHER) 내 것만 돌아온다
- 거절을 만드는 소스: lib/repository/item.ts

T08-C36 ~ C41



확인 ③ 이미 쓴 질문은 다시 통하지 않는다

실제 배포본에 보낸 요청과 그 응답

challenge 는 매번 다르고, 한 번만 쓰인다

- register 2회 + authenticate 1회의 challenge 가 전부 다름
- verify 는 서명 검증 전에 GETDEL 로 challenge 를 소비한다
- 그래서 재사용 요청은 400 으로 거절된다
- 이 화면은 스크립트가 배포본에 직접 보낸 요청·응답이다

T08-C19 · C20 · C27 · C28 · C31 · C33

실제 요청과 응답

C16 · C17 · C19 · C20 · C27 · C28 · C31 · C33

출처: scripts/render-evidence-views.mjs 가 https://webtest-passkey.vercel.app 에 직접 보낸 요청. Postman 화면이 아니라 스크립트가 보낸 실제 요청·응답이며, 세션 값은 남기지 않았다(C34).

거절되는 요청

무엇	요청 (쿠키 없음)	응답	기준
로그인 없이 비공개 자료 조회	GET /api/items	HTTP 401 { "error": "로그인이 필요합니다." }	C16 · C17 - 401 로 거절
로그인 없이 비공개 화면	GET /private	HTTP 307 location: /login	C15 - 로그인 화면으로 보냄

질문(challenge)은 매번 다르다

요청	돌아온 challenge (맞 24자)
POST /api/webauthn/register/options (1회차)	SramUGoGYS5uvvgTXyu0tV2rs...
POST /api/webauthn/register/options (2회차)	88V0daNiOS9XDkYcFa1Ww01J...
POST /api/webauthn/authenticate/options	1SPWaxgnbA49XDijRup9YrU1...

세 값이 서로 모두 다름 — C20 · C28

이미 쓴 질문은 다시 통하지 않는다

C31 · C33

요청	응답
POST /api/webauthn/authenticate/verify (challenge 첫 사용)	HTTP 400 { "error": "등록되지 않은 패스키입니다." }
POST /api/webauthn/authenticate/verify (같은 challenge 재사용)	HTTP 400 { "error": "인증 요청이 만료되었거나 이미 처리되었습니다." }

첫 요청에서 서명 검증에 실패하더라도 challenge 는 GETDEL 로 이미 소비된다. 그래서 재사용 요청은 “인증 요청이 만료되었거나 이미 처리되었습니다.” 로 거절된다.

확인 ④ 기기를 잃어버렸을 때

패스키 두 개를 등록하고, 하나를 지운 뒤에도 들어간다

등록된 패스키

서버에는 각 패스키의 공개키만 저장됩니다. 개인키는 기기 또는 비밀번호로 관리될 필요로 나가지 않습니다. 기기를 잃을 때를 대비해 두 개 이상 등록해 두세요.

이 PC (가상 인증기) 이용 변경

등록: 2026. 9. 4. 오후 9:38 · 마지막 사용 한 달 전
이 기기에 적용됨 (동거와 한 달)

추가 기기 (2026-09-04) 이용 변경

등록: 2026. 9. 4. 오후 9:38 · 마지막 사용 한 달
보안 키(U2F/NFC)에 저장됨

다른 패스키 등록

로그아웃

패스키를 추가했습니다.

비공개 자리 삭제

마지막 패스키는 삭제할 수 없습니다(계정 잠금 방지). 완전히 정리하려면 아래 버튼으로 자리 전체를 지웁니다 — 항목: 패스키, 세션이 모두 사라지고 로그인할 수 없게 됩니다.

비공개 자리와 모든 항목 삭제

패스키 2개 등록

이름 · 등록 날짜 · 저장 위치가 각각 보인다

휴우철 · PORTFOLIO

공개 스캐 비공개 영역

공개 영역

공개 스캐 데이터는 로그인 없이 누구나 볼 수 있습니다. 아래부터가 나만 보는 자리입니다.

비공개 항목

공개 중인 프로젝트 예외, 지원하려는 곳, 스스로 쓰는 참고자료 나만 보는 항목입니다. (실제 개인정보는 넣지 마세요 — 연결이 닿은 내용으로 송출합니다.)

이 항목 입력 (최대 500자)

등록 추가

준비 중: 공조생동 팔기 오답노트 정리

삭제

지원 목록: 설비관리 3곳, IT 헬프데스크 1곳

삭제

이번 주 회고: 패스키와 도메인 백업당(ppid)을 처음 이해함

삭제

등록된 패스키

서버에는 각 패스키의 공개키만 저장됩니다. 개인키는 기기 또는 비밀번호로 관리될 필요로 나가지 않습니다. 기기를 잃을 때를 대비해 두 개 이상 등록해 두세요.

추가 기기 (2026-09-04) 이용 변경

등록: 2026. 9. 4. 오후 9:38 · 마지막 사용 한 달 전
보안 키(U2F/NFC)에 저장됨

다른 패스키 등록

로그아웃

하나 지운 뒤 로그인

삭제한 기기 없이 남은 패스키로 들어갔다

휴우철 · PORTFOLIO

공개 스캐 비공개 영역

공개 영역

공개 스캐 데이터는 로그인 없이 누구나 볼 수 있습니다. 아래부터가 나만 보는 자리입니다.

비공개 항목

공개 중인 프로젝트 예외, 지원하려는 곳, 스스로 쓰는 참고자료 나만 보는 항목입니다. (실제 개인정보는 넣지 마세요 — 연결이 닿은 내용으로 송출합니다.)

이 항목 입력 (최대 500자)

등록 추가

준비 중: 공조생동 팔기 오답노트 정리

삭제

지원 목록: 설비관리 3곳, IT 헬프데스크 1곳

삭제

이번 주 회고: 패스키와 도메인 백업당(ppid)을 처음 이해함

삭제

등록된 패스키

서버에는 각 패스키의 공개키만 저장됩니다. 개인키는 기기 또는 비밀번호로 관리될 필요로 나가지 않습니다. 기기를 잃을 때를 대비해 두 개 이상 등록해 두세요.

추가 기기 (2026-09-04) 이용 변경

등록: 2026. 9. 4. 오후 9:38 · 마지막 사용 한 달 전
보안 키(U2F/NFC)에 저장됨

다른 패스키 등록

로그아웃

마지막 패스키는 삭제할 수 없습니다. 지우려면 '비공개 자리 삭제'를 사용하세요.

비공개 자리 삭제

마지막 패스키는 삭제할 수 없습니다(계정 잠금 방지). 완전히 정리하려면 아래 버튼으로 자리 전체를 지웁니다 — 항목: 패스키, 세션이 모두 사라지고 로그인할 수 없게 됩니다.

비공개 자리와 모든 항목 삭제

마지막 하나는 못 지운다

409 — 자리 잠금을 막는다

패스키가 하나도 남지 않는 상태는 만들지 않는다 — 마지막 패스키 삭제를 409 로 거절하고, 정리하려면 '비공개 자리 삭제'로 자리 전체를 지운다. (C46)

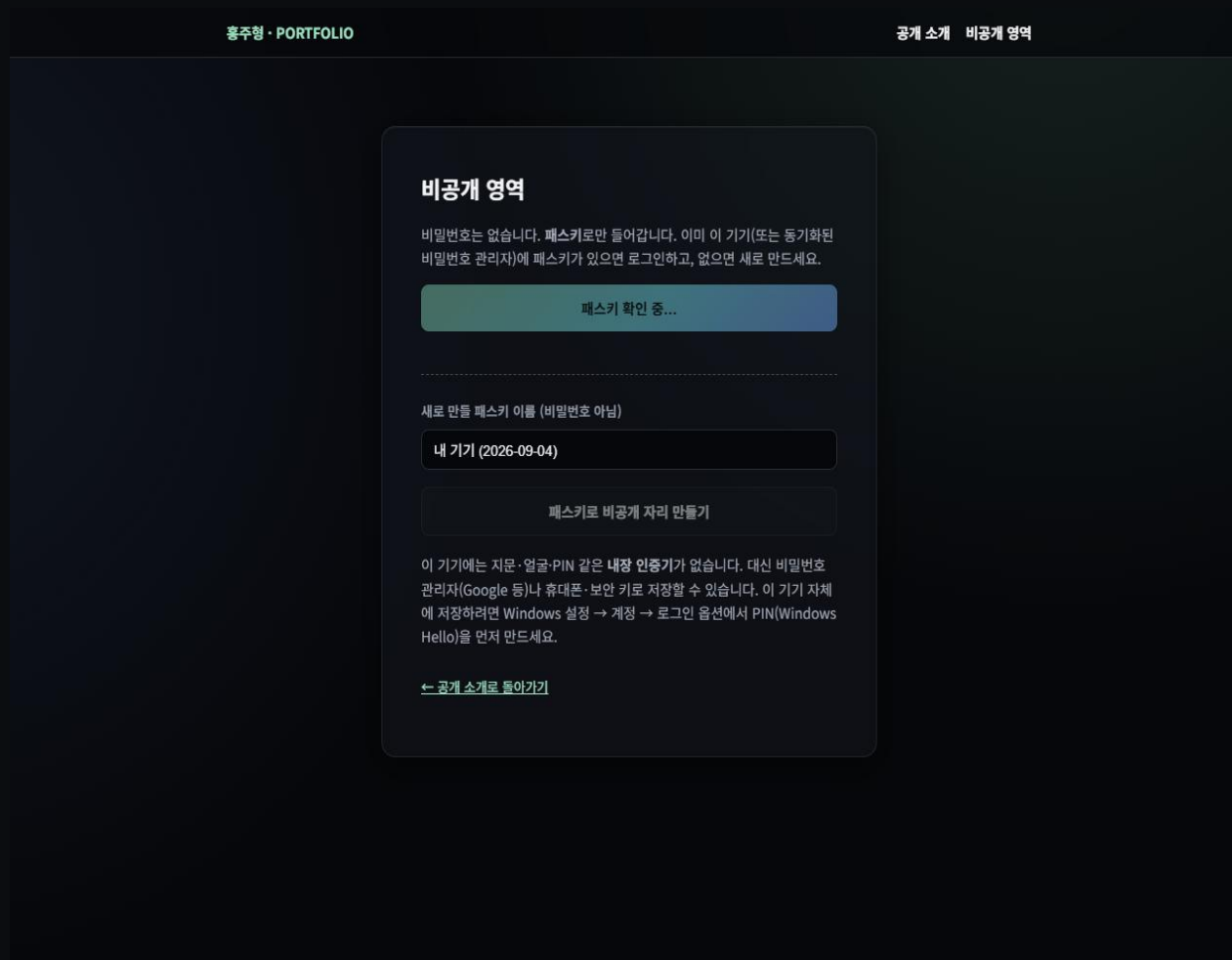
삭제한 패스키로는 못 들어간다

지운 뒤 그 기기로 시도하면 거절된다

서버에 없는 패스키 → 로그인 실패

- cred:{credentialId} 조회가 실패하면 400
- '등록되지 않은 패스키입니다'
- 삭제는 소유자 확인 후에만 — WHERE id AND spaceId에 해당하는 검사
- 즉, 남이 내 패스키를 지울 수 없다

T08-C45



서버에 저장된 것은 공개키다

비밀번호가 아니고, 개인키도 아니다

COSE 로 풀면 타원곡선 공개키

- $ky = 2$ (EC2) · $alg = -7$ (ES256) · $crv = 1$ (P-256)
- x, y — 곡선 위의 좌표 32바이트씩
- 개인키 d 는 없다. 인증기 밖으로 나오지 않기 때문
- 비밀번호·해시로 보이는 키: 0개
- 프로덕션 Redis 를 스크립트가 직접 조회한 결과

T08-C19 · C21 · C22 · C23

서버(Redis)에 실제로 저장된 것 (C19 · C21 · C22)

출처: scripts/render-evidence-views.js 가 프로덕션 Redis(REDIS_URL)에 직접 조회한 결과. Redis Cloud 콘솔 화면이 아니라 스크립트 조회 결과이며, scripts/show-stored-credential.js 로 같은 값을 다시 볼 수 있다.

키 전체 (15개)

키	형	TTL(초)	값
challenge:audit	list	-	LIST(68) [{"purpose":"authenticate","at":"2026-09-04T12:50:12Z","head":"5C3QVwKTrB6MIs"}], [{"purpose":"register","at":...}]
cred:f1NwXcHJ9EGHr_bKANPuYvFndR2aCyuI0TbS-Q1o8s	string	-	{"credentialId":"f1NwXcHJ9EGHr_bKANPuYvFndR2aCyuI0TbS-Q1o8s","spaceId":"6802d850-7fc1-418a-88f5-2c94a7fe64a5","publicKey":{"pQCAYyGASfYtGFB...}}
handle:49QzjcnCDlopIMxG-prgZA	string	-	"6802d850-7fc1-418a-88f5-2c94a7fe64a5"
item:3e21be32-a7e5-4637-879f-a0589652bf34	string	-	{"id":"3e21be32-a7e5-4637-879f-a0589652bf34","spaceId":"6802d850-7fc1-418a-88f5-2c94a7fe64a5","content":"임플란트 32인치 상하 더블모니터","createdAt":"2026-09-04T07:33Z"}
item:93683cd3-1199-4710-860f-7bfb8228f7d9	string	-	{"id":"93683cd3-1199-4710-860f-7bfb8228f7d9","spaceId":"6802d850-7fc1-418a-88f5-2c94a7fe64a5","content":"휴대폰 2개","createdAt":"2026-09-04T07:33Z"}
item:eeb03084-9b8b-4a78-a675-13c452c1313e	string	-	{"id":"eeb03084-9b8b-4a78-a675-13c452c1313e","spaceId":"6802d850-7fc1-418a-88f5-2c94a7fe64a5","content":"차량 : 니로하이브리드","createdAt":"2026-09-04T07:33Z"}
session:0f850cb1902f296a9235a076739b4a2d8666b246d6e2f383ca8abb13b1662423	string	585928	"6802d850-7fc1-418a-88f5-2c94a7fe64a5"
session:69a958c78796ac29f1a3e749cda66c3f37f971ac7f3a5cb5f4429b72aea0490d	string	585948	"6802d850-7fc1-418a-88f5-2c94a7fe64a5"
session:79cdf429651e8087361efc54fbc2eb094cc457f92bad7ab394f81ae06302f7c	string	585910	"6802d850-7fc1-418a-88f5-2c94a7fe64a5"
session:c36915f4f0f21f454db89357d148c08abd7822160109657d597095af97da6da9	string	585890	"6802d850-7fc1-418a-88f5-2c94a7fe64a5"
session:d125b0ef87312106d9543ca092a313bc0f1a6405ff327c6b8d494c85d2b549fc	string	585921	"6802d850-7fc1-418a-88f5-2c94a7fe64a5"
space:6802d850-7fc1-418a-88f5-2c94a7fe64a5	string	-	{"userHandle":"49QzjcnCDlopIMxG-prgZA","createdAt":"2026-09-04T07:36:07.633Z"}
space:6802d850-7fc1-418a-88f5-2c94a7fe64a5:creds	set	-	SET [{"f1NwXcHJ9EGHr_bKANPuYvFndR2aCyuI0TbS-Q1o8s"}]
space:6802d850-7fc1-418a-88f5-2c94a7fe64a5:items	list	-	LIST(3) [{"eeb03084-9b8b-4a78-a675-13c452c1313e"},"","3e21be32-a7e5-4637-879f-a0589652bf34"}]
space:6802d850-7fc1-418a-88f5-2c94a7fe64a5:sessions	set	-	SET [{"c36915f4f0f21f454db89357d148c08abd7822160109657d597095af97da6da9"},"79cdf429651e8087361efc54fbc2eb094cc457f92bad7ab394f81ae06302f7c"},""]

비밀번호·해시로 보이는 키: 0개 — 없음. 이 앱에는 비밀번호가 존재하지 않는다.

등록된 메스키 레코드 (cred:f1NwXcHJ9EGHr_bKANPuYvFndR2aCyuI0TbS-Q1o8s)

```
{
  "credentialId": "f1NwXcHJ9EGHr_bKANPuYvFndR2aCyuI0TbS-Q1o8s",
  "spaceId": "6802d850-7fc1-418a-88f5-2c94a7fe64a5",
  "publicKey": {"pQCAYyGASfYtGFB0dH1DLuFF50tu3Bs-CYxpQsp7KAl0kx5oleR_v1lggFXFvQ12zxH0x0kkjc56-At1pgvjvBTae09gQdxCGM"},
  "counter": 0,
  "deviceType": "multidevice",
  "backedUp": true,
  "transports": [
    "hybrid",
    "internal"
  ],
  "aaguid": "53414d53-554e-4700-0000-000000000000",
  "label": "내 기기 (2026-09-04)",
  "createdAt": "2026-09-04T07:36:07.990Z",
  "lastUsedAt": "2026-09-04T07:37:06.444Z"
}
```

위 publicKey 를 COSE 로 풀면

값	값	뜻
ky (1)	2	2 = EC2 — 타원곡선 공개키
alg (3)	-7	-7 = ES256
crv (-1)	1	1 = P-256
x (-2)	67c13673cbd4e2ee145b0e4eecd1b3e098c693b1...	곡선 위 좌표 (32바이트)
y (-3)	15716f422db3c611c6c679248dc4baf8020ba60b...	곡선 위 좌표 (32바이트)
d	없음	개인키. 인증기 밖으로 나오지 않아 서버에 없다

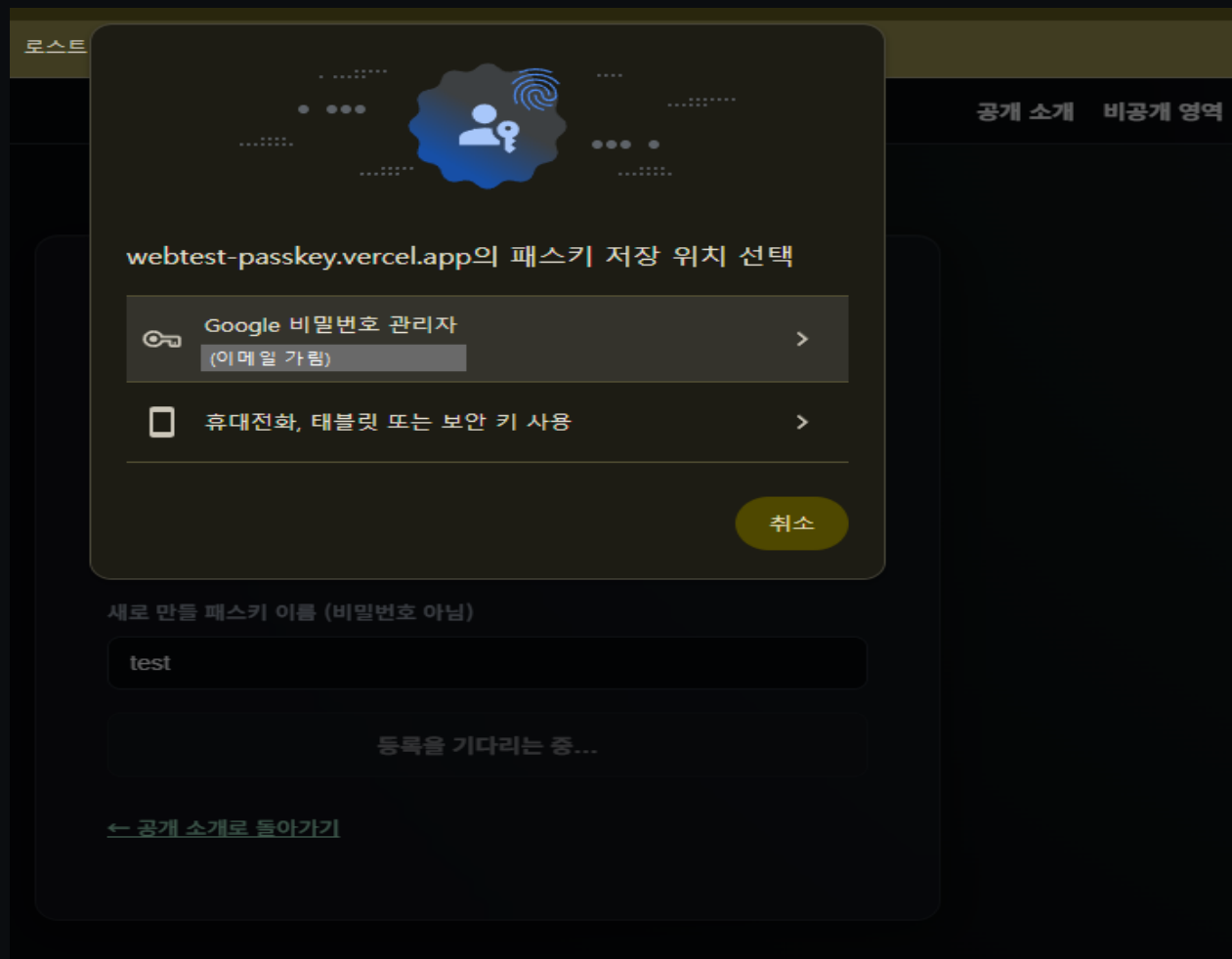
패스키를 어디에 저장했나

실기기에서 구글 비밀번호 관리자로 등록

저장 위치를 사용자가 고른다

- Chrome 이 저장 위치 선택창을 띄운다
- Google 비밀번호 관리자 / 휴대전화·태블릿 또는 보안 키
- 실제로 등록된 것은 삼성 기기의 동기화되는 패스키
- (aaguid = SAMSUNG, backedUp = true, transports = hybrid-internal)
- 화면의 계정 이메일은 가렸다 — 제출물에 개인정보 없음

T08-C24 · C25 · C26



비밀번호를 입력하는 칸이 없다

제출물 어디에도 비밀번호 입력란이 존재하지 않는다

입력칸은 '패스키 이름' 하나뿐

- [패스키로 로그인] — 아이디도 비밀번호도 묻지 않는다 (usernameless)
- 아래 입력칸은 새로 만들 패스키의 이름이며 비밀 값이 아니다
- 화면에도 '(비밀번호 아님)' 이라고 적어 두었다
- test/routes.test.mjs 가 type="password" 와 bcrypt·argon2 등을 정적으로 검사한다

T08-C35

홍주형 · PORTFOLIO

공개 소개비공개 영역

비공개 영역

비밀번호는 없습니다. 패스키로만 들어갑니다. 이미 이 기기(또는 동기화된 비밀번호 관리자)에 패스키가 있으면 로그인하고, 없으면 새로 만드세요.

패스키로 로그인

새로 만들 패스키 이름 (비밀번호 아님)

이 PC (가상 인증기)

패스키로 비공개 자리 만들기

[← 공개 소개로 돌아가기](#)

지어낸 내용이라는 사실을 적었다

제출물에 실제 개인정보가 없다

공개 페이지 하단의 고지

- '이 소개 페이지의 내용은 학습·연습용으로 지어낸 (fabricated) 것입니다'
- '실제 연락처·주소·신분증 번호 같은 개인정보는 넣지 않았습니다'
- 공개 범위 표에 '공개하지 않는 것'을 항목명만 적고 실제 값은 넣지 않았다
- 비공개 항목도 전부 지어낸 내용 — 증거 색인 맨 위에 명시했다

T08-C12

Python

학습 중

IT 전반에 대한 이해를 넓히려고 첫 프로그래밍 언어로 독학을 시작했습니다.

MySQL

학습 중

데이터를 구조적으로 다루는 감각을 익히려고 함께 학습했습니다.

공개 범위

공개하는 것

공개하지 않는 것

최근 공부한 내용: Python, MySQL

집 주소

취미: 게임, 야구

전화번호

관심 분야: IT

이메일 주소

이 소개 페이지의 내용은 학습·연습용으로 지어낸(fabricated) 것입니다. 실제 연락처·주소·신분증 번호 같은 개인정보는 넣지 않았습니다. 아래 "비공개 영역"은 패스키로 잠긴 별도의 자리이며, 심사할 때는 이 공개 페이지까지만 보시면 됩니다.

비공개 영역

준비 중인 메모처럼 나만 보는 자리입니다. 비밀번호 없이 패스키로만 잠겨 있습니다.

비공개 영역 열기 →

© 2026 홍주형 · 과제 8 (패스키 인증)

패스키 하나를 지운 직후

두 개 중 하나를 지우면 목록에 하나만 남는다

삭제는 소유자 확인 후에만

- cred:{id} 의 spaceId 가 세션의 자리와 같을 때만 지운다
- 남이 내 패스키를 지울 수 없다 (다르면 404 — 존재조차 숨긴다)
- '패스키를 삭제했습니다. 남은 패스키로 계속 로그인 할 수 있습니다.'
- 이 상태에서 삭제한 기기를 없애고 로그인하면 다음 장치럼 된다

T08-C44

새 항목 입력 (최대 500자)

항목 추가

준비 중: 공조냉동 펌프 오답노트 정리

삭제

지원 목록: 설비관리 3곳, IT 헬프데스크 1곳

삭제

이번 주 회고: 패스키의 도메인 바인딩(rpid)을 처음 이해함

삭제

등록된 패스키

서버에는 각 패스키의 공개키만 저장됩니다. 개인키는 기기(또는 비밀번호 관리자) 밖으로 나가지 않습니다. 기기를 잃을 때를 대비해 두 개 이상 등록해 두세요.

추가 기기 (2026-09-04) 이름 변경

삭제

등록: 2026. 9. 4. 오후 9:38 · 아직 사용 안 함
보안 키(USB/NFC) 에 저장됨

다른 패스키 등록

로그아웃

패스키를 삭제했습니다. 남은 패스키로 계속 로그인할 수 있습니다.

비공개 자리 삭제

마지막 패스키는 삭제할 수 없습니다(계정 잠금 방지). 완전히 정리하려면 아래 버튼으로 자리 전체를 지웁니다 — 항목·패스키·세션이 모두 사라지고 로그인할 수 없게 됩니다.

비공개 자리와 모든 항목 삭제

짧은 확인 방법 4줄

심사하는 분이 30초 안에 확인하는 법

어디로 가나요

①

<https://webtest-passkey.vercel.app> 을 새 시크릿 창에서 엽니다.
심사하는 분은 공개 소개 페이지까지만 보면 되고, 잠긴 자리는 열지 않아도 됩니다.

세 단계 안에 무엇을 하나요

②

(1) 열어서 공개 소개를 봅니다 → (2) 주소창에 /private 를 칩니다 →
(3) [패스키로 비공개 자리 만들기] 를 누르고 기기 인증(지문·PIN)을 합니다.

무엇이 보이면 통과인가요

③

(1) 공개 소개와 '지어낸 내용' 고지, (2) /private 은 잠겨 로그인 화면이 뜨고
비공개 항목은 화면에도 페이지 소스에도 없음, (3) 패스키를 만든 뒤에만 내 항목이 보임.

안 될 때는 무엇이 보이나요

④

미로그인 GET /api/items → 401. 로그아웃 뒤 이전 세션 재사용 → 401.
이미 쓴 인증 요청 재사용 → 400. 남의 패스키·남의 항목 주소 → 400 / 404.

인증 구현 설명서 ⑤ · AI와 내 판단 3줄

무엇을 맡겼고, 무엇을 내가 정했고, 무엇을 따르지 않았나

① AI에게 맡긴 일

webtest 정적 사이트의 Next.js 이식, @simplewebauthn 서버·브라우저 연동(등록·로그인 ceremony), 불투명 세션과 자리 격리 로직, P-256 소프트웨어 인증기와 자동 검증·촬영 스크립트, 문서 초안 작성.

② 내가 직접 판단한 일

회원가입을 만들지 않고 '패스키를 처음 등록하면 그 사람 몫의 비공개 자리가 생긴다'로 모델을 정한 것. 등록 입력을 패스키 이름 한 칸으로 제한한 것. 비공개 항목은 추가·삭제만 두고 수정 기능을 뺀 것. 마지막 패스키는 삭제할 수 없게(계정 잠금 방지) 한 것. 저장소를 관계형 DB 대신 Redis로 정하고 새 저장소·Vercel 프로젝트로 분리한 것.

③ AI 제안을 따르지 않은 일

AI가 처음 설계에 넣었던 '계정 이름 입력칸'과 '비공개 노트 수정 기능(CRUD)'을, 과제 8이 요구하지 않는 범위라고 판단해 걷어냈다. AI가 대안으로 제시한 비밀번호 풀백·이메일 복구도 넣지 않았고, 대신 '모든 기기를 잃으면 복구할 수 없다'를 설명서 ⑥의 첫 항목으로 명시했다.

인증 구현 설명서 ⑥ 아직 못 막은 것

'없다'고 적으면 통과하지 않는 항목 — 여섯 가지를 구체적으로

1 비공개 자리 복구 수단이 없다

등록한 기기를 모두 잃으면 그 자리와 항목에 영원히 접근할 수 없다. 이메일·복구코드가 없다. 운영 서비스라면 복구 코드나 관리자 복구가 필요하다.

2 레이트리미트가 없다

`/api/webauthn/*/options` 를 무제한 호출할 수 있어 Redis 쓰기와 `challenge:audit` 증가를 유발한다. 각 `challenge` 는 5분 TTL 로 사라지지만 요청 자체는 못 막는다.

3 userVerification 이 preferred 다

잠금 해제된 기기를 그대로 훔치면 지문·PIN 없이도 인증될 수 있다. 호환성을 위해 `required` 대신 택했다.

4 attestationType 이 none 이다

어떤 인증기가 만든 패스키인지 검증하지 않는다(개인 사이트라 수용). 따라서 '어디에 저장됐는지' 문구는 `flags.transports` 휴리스틱이라 틀릴 수 있다.

5 CSRF 토큰이 없다

SameSite=Lax 쿠키 + JSON content-type + WebAuthn 의 origin 바인딩에 의존한다.

6 인메모리 풀백은 로컬 전용이다

한 프로세스가 죽으면 사라진다. 프로덕션에서 절대 커지지 않도록 `NODE_ENV=production` 이면 예외를 던진다.

실제로 겪은 문제와 해결

문제 → 시도 → 비교 → 해결 (겪은 것만 적었다)

문제	무엇이 원인이었나	어떻게 고쳤나
배포는 됐는데 등록만 500	Vercel 통합이 준 것은 Redis Cloud 의 REDIS_URL(TCP)이고 REST 엔드포인트가 없었다. KV_REST_API_* 는 통합보다 먼저 등록된 플레이스홀더였다	@upstash/redis(REST) → ioredis(TCP) 로 교체. 어댑터에서 JSON 직렬화 처리
Windows 가 곧장 '보안 키를 USB 에'	usernameless 요청(allowCredentials 비움)에 hints 가 없어 Windows 네이티브 WebAuthn 이 보안키 경로로 해석	hints: [client-device, hybrid, security-key] 추가. 제한이 아니라 순서 제안이라 기기 2개 요구가 안 깨진다
로그인 성공 후 자동 이동이 안 됨	fetch 응답의 Set-Cookie 로 세션이 막 생긴 직후 router.replace() 로 넘기면 라우터 캐시가 이전 상태를 들고 있다	window.location.replace() 전체 로드로 변경 — 브라우저가 새 쿠키를 실어 보낸다
인메모리 kv 가 요청마다 초기화되는 것처럼 보임	Next dev 가 라우트를 따로 번들해 모듈 스코프 싱글톤이 공유되지 않았다	globalThis 에 인스턴스를 붙여 한 프로세스에 하나만 쓰도록
Next.js 16 이 middleware 를 deprecated 로 경고	Next 16 부터 proxy 로 이름이 바뀜	middleware.ts → proxy.ts, export function proxy 로 변경

배운 점 — 'Vercel Storage 의 Redis' 는 한 제품이 아니다. 어떤 벤더가 붙었는지는 접속 문자열의 호스트를 봐야 한다. 그리고 선택지를 좁혀 고치는 것과 순서를 제안해 고치는 것은 결과가 다르다.

검증 결과

말 대신, 배포본에 실제로 보낸 요청과 그 응답

확인	성공	거절	결과
질문이 매번 다르다	등록 5 + 로그인 5 = 10개 전부 상이	—	통과
서명 검증	정상 서명 → 200	1바이트 변조 서명 → 401	통과
질문 재사용	첫 사용 → 200	재사용 → 400	통과
미로그인 조회	로그인 후 → 200 (3건)	쿠키 없이 → 401 · /private → 307	통과
로그아웃 뒤 재사용	—	이전 세션 쿠키 → 401	통과
패스키 2개 → 삭제	남은 패스키 로그인 → 200	삭제된 패스키 → 400 · 마지막 삭제 → 409	통과
자리 간 격리	각 자리 자기 항목 → 201	A↔B 양방향 → 404 · 건수 3→3 불변	통과

재현 방법 npm run typecheck · npm test (8/8) · node scripts/verify-webauthn.mjs (all_pass)

node scripts/capture-evidence.mjs (화면 자동 촬영) · node scripts/render-evidence-views.mjs (DB·요청응답)

통과 기준 47개

카드 1~5 전부 충족 — 근거 파일까지 1:1 로 매핑

카드 1

무엇을 잠글지 가르다

C13 ~ C18

6개

카드 2

패스키를 등록한다

C19 ~ C26

8개

카드 3

패스키로 들어간다

C27 ~ C35

9개

카드 4

기기를 잃어버렸을 때

C42 ~ C46

5개

카드 5

정말 안 열리는지 확인

C01·C02·C03·C10~C12
C36~C41 · C47~C53

19개

docs/00_과제_요구사항_매핑.md — 기준마다 '요구 / 충족 위치(소스 파일) / 증거 파일 / 상태' 네 칸으로 적었다. 미완(●) 0개.

증거는 PNG 15장 + 요청·응답 기록 13개. 실기기 등록 프롬프트 1장을 빼면 전부 스크립트로 재생성할 수 있다.

제출물 어디에도 실제 개인정보와 비밀값이 없다 — 세션 값은 <redacted>, 계정 이메일은 마스킹, 비공개 항목은 전부 지어낸 내용.

배포 구성

Next.js 기본 빌드 + Redis 통합 — 설정 파일 없음



- 쿠키 Secure 는 `NODE_ENV=production` 에서 자동. WebAuthn 은 secure context(HTTPS 또는 localhost)에서만 동작한다.
- 패스키는 정확한 도메인에 묶인다 — 프리뷰 도메인에서 만든 패스키는 프로덕션에서 통하지 않는다(정상 동작). 커스텀 도메인을 붙이면 `WEBAUTHN_*` 을 다시 맞춰야 하고 기존 패스키는 무효가 된다.
- `NEXT_PUBLIC_*` 을 쓰지 않는다. 세션 서명키도 없다(불투명 토큰이라 서명할 것이 없다).
- 로컬에 `REDIS_URL` 이 없으면 인메모리 KV 로 폴백해 화면 확인이 가능하고, 프로덕션에서는 예외를 던져 절대 켜지지 않는다.
- `challenge:audit` 는 최근 200개로 capped(LTRIM). 그 외 challenge 키는 5분 TTL 로 자동 소멸한다.
- 원본 webtest 저장소와 GitHub Pages 배포는 건드리지 않았다 — 과제 1 자산 불가침.

비밀번호를 없애면 무엇이 그 자리를 채우는가

1 공개키

서버가 가진 것은 검증에만 쓰는 공개키뿐. 개인키는 기기 밖으로 나오지 않는다.

2 일회용 질문

로그인마다 서버가 새 challenge 를 내고, 한 번 쓰이면 GETDEL 로 사라진다.

3 기기 분실 대비

패스키를 두 개 등록해 두면 하나를 잃어도 들어간다. 마지막 하나는 지울 수 없다.